

Ataques a las credenciales

Seguridad en Sistemas Informáticos — Tema 3.1

José Luis Martínez

Universidad de Castilla-La Mancha

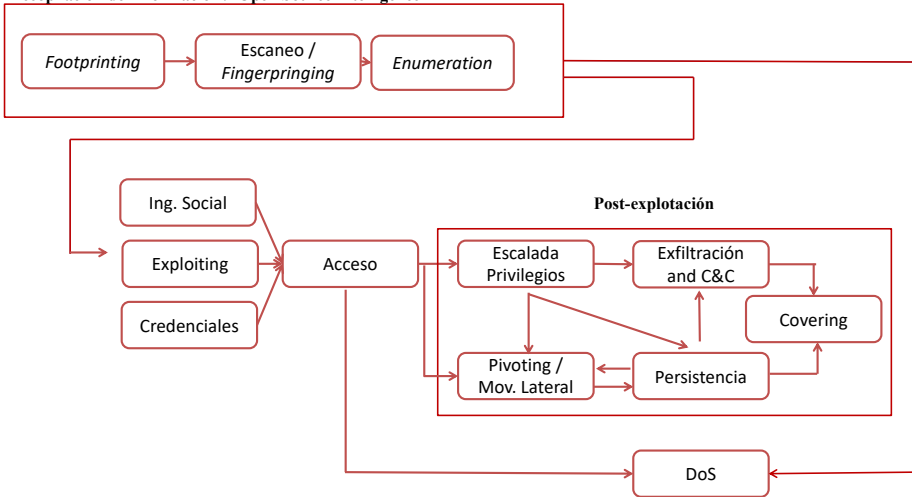
Curso 2026/27

- 1 Introducción
- 2 Ataques online activos
- 3 Ataques de fuerza bruta
- 4 Malware
- 5 Ataques offline
- 6 Captura de credenciales en red: LLMNR/NBT-NS
- 7 Ataques a tokens en la nube
- 8 Ejercicios
- 9 Referencias

- 1 Introducción
- 2 Ataques online activos
- 3 Ataques de fuerza bruta
- 4 Malware
- 5 Ataques offline
- 6 Captura de credenciales en red: LLMNR/NBT-NS
- 7 Ataques a tokens en la nube
- 8 Ejercicios
- 9 Referencias

Introducción

Recopilación de Información / Open Source Intelligence



- Tras la fase de recopilación de información se habrán identificado la mayoría de los activos de la organización; entre ellos, servicios o aplicaciones que requieran un proceso de autenticación, por ejemplo: SSH, FTP, RDP, un CMS, dominios, etc.
- En un pentesting, cuyo objetivo es demostrar que el sistema es vulnerable a ataques de acceso, el vector de ataque o intrusión puede ser
 - Aprovechar los propios servicios de acceso con autenticaciones débiles o ataques sobre estos (lo abordamos en este módulo 3.1)
 - Utilizar técnicas de ingeniería social para conseguir credenciales válidas engañando al usuario o bien que ejecute algún payload camuflado de tipo RCE (lo veremos en el tema 3.2)
 - Explotar una vulnerabilidad que permita la ejecución remota de código (se verá en el módulo 3.3)

Dentro de los ataques a las credenciales, se pueden identificar:

- **Ataques online activos:** se interactúa con el servicio intentando averiguar el par `user:pass`
 - Credenciales por defecto
 - Reutilización de contraseñas
 - Ataques de fuerza bruta
 - Ataques basados en diccionario
 - Malware (keylogger, spyware)
 - Pass-the-Hash (es más de postexplotación — pivoting)
- **Ataques online pasivos:** se escuchan las comunicaciones y se esnifan credenciales válidas o sesiones activas (se verán en el módulo de sniffing)
 - Session Replay (por ejemplo, a través de un XSS y robo de la cookie de sesión)
 - Tablas rainbow
- **Ataques no electrónicos:** los derivados de la ingeniería social, y los ataques online activos mejorados con ella (se verán en el tema 3.2)

- 1 Introducción
- 2 Ataques online activos**
- 3 Ataques de fuerza bruta
- 4 Malware
- 5 Ataques offline
- 6 Captura de credenciales en red: LLMNR/NBT-NS
- 7 Ataques a tokens en la nube
- 8 Ejercicios
- 9 Referencias

Credenciales por defecto

- En términos generales, los ataques a las credenciales consisten en averiguar el par `user:pass`. En una primera aproximación, si en la fase de fingerprinting hemos identificado un servicio o aplicación, podemos probar con las credenciales por defecto de dicho servicio o aplicación.
- Algunos repositorios para averiguar credenciales por defecto:
 - [DefaultCreds-cheat-sheet](#)
 - [SecLists — Default Credentials](#)
 - [WordList-Compendium](#)
 - [CIRT.net — Default Passwords](#)
 - [passwordsdatabase.com](#)
 - [DataRecovery — Default Passwords](#)
 - [bizuns.com — Default Passwords List](#)
 - [Default Router Passwords List](#)
 - [HackTricks — Brute Force](#) (más repositorios)
- Herramientas para comprobar credenciales por defecto:

Credenciales por defecto

- **changeme**: a partir de una IP, identifica los puntos de autenticación y prueba credenciales por defecto
- **gitleaks**: busca en repositorios de código contraseñas hardcodeadas, API keys, tokens, etc.

Reutilización de contraseñas

- Otra alternativa para comprometer un servicio de autenticación es comprobar la reutilización de credenciales.
- Un alto porcentaje de contraseñas, aun siendo seguras (no aparecen en diccionarios, contienen un espacio de caracteres elevado y una longitud robusta), son reutilizadas por parte de un mismo usuario en diferentes servicios o aplicaciones.
- Existen aplicaciones que buscan leaks de contraseñas de unos servicios para comprobar si esa contraseña se usa en otros.
- Sitios donde buscar leaks:
 - [Have I Been Pwned](#): comprobación de correos electrónicos afectados por brechas de datos conocidas
 - [Mozilla Monitor](#): monitorización de la exposición de direcciones de correo en filtraciones
 - [DeHashed](#): motor de búsqueda de información procedente de filtraciones de datos
 - [Intelligence X](#): plataforma de inteligencia y búsqueda de información expuesta
 - [BreachDirectory](#): consulta de información asociada a brechas de datos

Reutilización de contraseñas

- [Google](#) / [Bing](#): búsqueda de información expuesta o indexada públicamente
- Herramientas:
 - [Cr3dOv3r](#): dado un correo, busca leaks conocidos y prueba las contraseñas encontradas en otros servicios
 - [pwndb](#): busca en la deep web filtraciones de datos con contraseñas de posibles usuarios
- Contramedida: contraseñas únicas por servicio (gestor de contraseñas) y segundo factor (MFA). Véase la [OWASP Credential Stuffing Prevention Cheat Sheet](#).

- 1 Introducción
- 2 Ataques online activos
- 3 Ataques de fuerza bruta**
- 4 Malware
- 5 Ataques offline
- 6 Captura de credenciales en red: LLMNR/NBT-NS
- 7 Ataques a tokens en la nube
- 8 Ejercicios
- 9 Referencias

Ataques fuerza bruta

- Otra alternativa es probar todas las combinaciones posibles, lo que se denomina ataques de fuerza bruta
- El tiempo de éxito es exponencial al tamaño de la clave y al espacio de caracteres que se usa



Time it takes a Hacker to Brute Force your password					
@coders.bro					
Numbers of Character	Numbers Only	Lowercase Letters	Upper and Lowercase Letters	Numbers, Upper and Lowercase Letters	Numbers, Upper and Lowercase Letters, Symbols
4	Instantly	Instantly	Instantly	Instantly	Instantly
5	Instantly	Instantly	Instantly	Instantly	Instantly
6	Instantly	Instantly	Instantly	1 sec	5 secs
7	Instantly	Instantly	25 secs	1 min	6 mins
8	Instantly	5 Secs	22 mins	1 hour	8 hours
9	Instantly	2 mins	19 hours	3 days	3 weeks
10	Instantly	58 mins	1 month	7 months	5 years
11	2 secs	1 day	5 years	41 years	400 years
12	25 secs	3 weeks	300 years	2k years	34k years
13	4 mins	1 year	16k years	100k years	2m years
14	41 mins	51 years	800k years	9m years	200m years
15	6 hours	1k years	43m years	600m years	15bn years
16	2 days	34k years	2bn years	37bn years	1tn years
17	4 weeks	800k years	100bn years	2tn years	93tn years
18	9 months	23m years	6tn years	100tn years	7qd years
Are you in green zone?					

Ataques fuerza bruta

Ataques basados en diccionario

- Otra opción es probar con una combinación de usuarios y contraseñas definidas en un fichero, en lo que se denomina ataques basados en diccionario
- El éxito del ataque pasa por que la contraseña esté en el diccionario y por encontrar un usuario válido (enumeración)
- Diccionarios:
 - RockYou, en `/usr/share/wordlists/`
 - Descomprimir con `gunzip rockyou.txt.gz`
 - Kaonashi
 - SecLists



Creación de diccionarios

- **crunch**: genera diccionarios a partir de un patrón (longitud y juego de caracteres)
- **Mentalist**: generador gráfico basado en reglas de mutación
- **maskprocessor**: generador por máscaras, de los autores de Hashcat
- **pydictor**: generador y analizador de diccionarios
- **CeWL**: construye el diccionario con las palabras de una web (muy útil en CTFs)
- **psudohash**: crea un diccionario a partir de otro aplicando mutaciones típicas, por ejemplo `Microsoft` → `M!cr0s0ft`
- **gorilla**: mezcla las capacidades de crunch, cupp, CeWL y las reglas de mutación
- Con ingeniería social (se verá en el tema 3.2): **cupp**, que construye el diccionario a partir de datos personales de la víctima

Ataques fuerza bruta

- **PassGAN** es una herramienta de cracking basada en Redes Generativas Adversariales (GAN). Aprende la distribución estadística de contraseñas reales y genera candidatos nuevos, no incluidos en ningún diccionario.
- ¿Cómo funciona?
 - Un generador (Generator) aprende patrones de millones de contraseñas reales filtradas (RockYou, LinkedIn...)
 - Un discriminador (Discriminator) evalúa si las contraseñas generadas parecen humanas
 - El resultado: contraseñas estadísticamente plausibles que escapan a los diccionarios clásicos
- Uso básico:
 - `python3 passgan.py --pretrained-model pretrained/gan.ckpt`
 - `--output-file passwords.txt -n 1000000`
 - # Genera 1M de candidatos; combinar luego con Hashcat o John
- Resultados y contexto:

Ataques fuerza bruta

- Reporta un 51–73 % más de contraseñas únicas frente a Hashcat + RockYou en ciertos datasets
 - Más lento que Hashcat puro: es ideal para ataques dirigidos, no por volumen
 - Tendencia: los modelos GAN y LLM aplicados a password cracking son cada vez más eficaces
- Artículo original: Hitaj et al., *PassGAN: A Deep Learning Approach for Password Guessing*, ACNS 2019 — [arXiv:1709.00440](https://arxiv.org/abs/1709.00440)

Ataques fuerza bruta

Herramientas

- **hydra** y **medusa**: fuerza bruta paralelizada contra decenas de protocolos de autenticación
 - `hydra -l msfadmin -P rockyou.txt ssh://<IP>`
 - `medusa -h <IP> -u msfadmin -P rockyou.txt -M ssh`
 - Ejemplo de uso frente a distintos servicios

```
root@kali:~/Desktop# hydra -L user.txt -P pass.txt 192.168.1.103 ftp
Hydra v8.6 (c) 2017 by van Hauser/THC - Please do not use in military or secret service or
Hydra (http://www.thc.org/thc-hydra) starting at 2018-09-28 12:03:32
[DATA] max 16 tasks per 1 server, overall 16 tasks, 36 login tries (l:6/p:6), ~3 tries per
[DATA] attacking ftp://192.168.1.103:21/
[21][ftp] host: 192.168.1.103 login: msfadmin password: msfadmin
[21][ftp] host: 192.168.1.103 login: service password: service
[21][ftp] host: 192.168.1.103 login: user password: user
[21][ftp] host: 192.168.1.103 login: postgres password: postgres
1 of 1 target successfully completed, 4 valid passwords found
[WARNING] Writing restore file because 1 final worker threads did not complete until end.
[ERROR] 1 target did not resolve or could not be connected
[ERROR] 16 targets did not complete
Hydra (http://www.thc.org/thc-hydra) finished at 2018-09-28 12:03:39
```

Ataques fuerza bruta

```
root@kali:~# nmap -p21 --script ftp-brute.nse --script-args userdb=/root/Desktop
/user.txt,passdb=/root/Desktop/pass.txt 192.168.1.105

Starting Nmap 7.25BETA1 ( https://nmap.org ) at 2016-08-23 04:38 EDT
Nmap scan report for 192.168.1.105
Host is up (0.00062s latency).
PORT      STATE SERVICE
21/tcp    open  ftp
| ftp-brute:
|   Accounts:
|     msfadmin:msfadmin - Valid credentials
|   Statistics: Performed 45 guesses in 13 seconds, average tps: 3
MAC Address: 00:0C:29:33:42:93 (VMware)

Nmap done: 1 IP address (1 host up) scanned in 14.82 seconds
```

Ataques fuerza bruta

Herramientas

- Nmap también hace fuerza bruta, con sus scripts NSE
- El motor **NSE** incluye scripts `*-brute` para docenas de protocolos: útil cuando ya estás escaneando con Nmap y quieres auditar credenciales sin cambiar de herramienta. [Ejemplo](#)

- Ejemplos por servicio:

- `nmap -p21 --script ftp-brute --script-args userdb=users.txt,passdb=pass.txt <IP>`
- `nmap -p22 --script ssh-brute --script-args userdb=users.txt,passdb=pass.txt <IP>`
- `nmap -p23 --script telnet-brute --script-args userdb=users.txt,passdb=pass.txt <IP>`
- `nmap -p445 --script smb-brute --script-args userdb=users.txt,passdb=pass.txt <IP>`
- `nmap -p3306 --script mysql-brute --script-args userdb=users.txt <IP>`
- `nmap -p5432 --script pgsq-brute --script-args userdb=users.txt,passdb=pass.txt <IP>`
- `nmap -p1433 --script ms-sql-brute --script-args userdb=users.txt,passdb=pass.txt <IP>`
- `nmap -p80 --script http-form-brute --script-args "http-form-brute.path=/login<IP>`

- Descubrir todos los scripts de fuerza bruta:

Ataques fuerza bruta

- `locate *.nse | grep -i brute`
- Los aciertos se guardan en el registro de Nmap (librería `creds`) para reutilizarlos en otros scripts

```
root@kali:~# nmap -p21 --script ftp-brute.nse --script-args userdb=/root/Desktop/user.txt,passdb=/root/Desktop/pass.txt 192.168.1.105

Starting Nmap 7.25BETA1 ( https://nmap.org ) at 2016-08-23 04:38 EDT
Nmap scan report for 192.168.1.105
Host is up (0.00062s latency).
PORT      STATE SERVICE
21/tcp    open  ftp
| ftp-brute:
|   Accounts:
|     msfadmin:msfadmin - Valid credentials
|   Statistics: Performed 45 guesses in 13 seconds, average tps: 3
NAC Address: 00:0C:29:33:42:93 (VMware)

Nmap done: 1 IP address (1 host up) scanned in 14.82 seconds
```

Herramientas

- **Metasploit** también dispone de varios módulos auxiliares para realizar ataques basados en diccionario frente a diferentes servicios
 - `search type:auxiliary login`
 - `use auxiliary/scanner/ssh/ssh_login`

Ataques fuerza bruta

```
msf > use auxiliary/scanner/ftp/ftp_login
msf auxiliary(ftp_login) > set rhosts 192.168.0.106
rhosts => 192.168.0.106
msf auxiliary(ftp_login) > set user_file /root/Desktop/user.txt
user_file => /root/Desktop/user.txt
msf auxiliary(ftp_login) > set pass_file /root/Desktop/pass.txt
pass_file => /root/Desktop/pass.txt
msf auxiliary(ftp_login) > set stop_on_success true
stop_on_success => true
msf auxiliary(ftp_login) > exploit
```

```
[*] 192.168.0.106:21 - 192.168.0.106:21 - Starting FTP login sweep
[-] 192.168.0.106:21 - 192.168.0.106:21 - 
[-] 192.168.0.106:21 - 192.168.0.106:21 - 
[-] 192.168.0.106:21 - 192.168.0.106:21 - 
[-] 192.168.0.106:21 - 192.168.0.106:21 - 
[-] 192.168.0.106:21 - 192.168.0.106:21 - 
[-] 192.168.0.106:21 - 192.168.0.106:21 - 
[-] 192.168.0.106:21 - 192.168.0.106:21 - 
[-] 192.168.0.106:21 - 192.168.0.106:21 - 
[-] 192.168.0.106:21 - 192.168.0.106:21 - 
[-] 192.168.0.106:21 - 192.168.0.106:21 - 
[-] 192.168.0.106:21 - 192.168.0.106:21 - 
[-] 192.168.0.106:21 - 192.168.0.106:21 - 
[-] 192.168.0.106:21 - 192.168.0.106:21 - 
[-] 192.168.0.106:21 - 192.168.0.106:21 - 
[-] 192.168.0.106:21 - 192.168.0.106:21 - 
[+] 192.168.0.106:21 - 192.168.0.106:21 - Login Successful: raj:123
[*] Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
```

Ejercicio

- Realiza un ataque de diccionario frente a los servicios SSH y FTP de la máquina Metasploitable2, fijando como usuario `msfadmin` y usando un diccionario cualquiera de Kali
 - Nota: puedes encontrar diccionarios en `/usr/share/wordlists/`
- Realiza el ejercicio con las herramientas:
 - hydra o medusa
 - Metasploit
 - NSE de Nmap



Ejercicio



- Realiza un ataque de autenticación online (basado en diccionario) frente a la base de datos PostgreSQL de la distribución Metasploitable2 usando Metasploit

Ejercicio

- Realiza un ataque de autenticación online (basado en diccionario) frente al servicio RDP (Remote Desktop Protocol) a un Windows, por ejemplo un [Win7](#):
- Ejemplo



Ejercicio

¡Nivel Examen!

- Resuelve la máquina **Poster** de TryHackMe, necesitarás:
 - Escanear
 - Usa metasploit para enumerar en el postgres
 - Usa metasploit para hacer fuerza bruta al postgres
- Nota: Para elevar privilegios en la máquina root hacerlo como ejercicio del tema de postexploitación



Ataques fuerza bruta

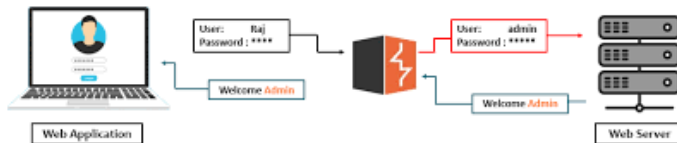
Fuerza bruta contra un login web

- Hacer ataques de fuerza bruta o de diccionario contra un panel o login web no es tan trivial como hacerlo frente a servicios SSH, Telnet, MySQL, etc.
- ¿Por qué? Dichos servicios llevan el proceso de autenticación implementado de manera intrínseca en el propio protocolo. Las herramientas simplemente implementan el protocolo y cambian el par `user:pass` en cada petición al servicio.
- El problema viene al hacer esto frente a una aplicación o formulario web, ya que el protocolo HTTP/HTTPS no lleva de manera intrínseca el proceso de autenticación: quien lo implementa es la propia aplicación web.
- Por tanto, debemos comunicarnos con la lógica de la aplicación usando HTTP/HTTPS. Para ello hay que ver cómo se construye la petición que envía el navegador (usuario) al servidor (aplicación web) y parametrizarla con diferentes usuarios y contraseñas.
- Para hacer esto nos apoyamos en proxies web como [Burp Suite](#) o [OWASP ZAP](#). En el caso de Burp Suite, en la pestaña *Intruder*.

Ataques fuerza bruta

- Nos ponemos en medio entre el navegador y la aplicación web (proxy), usando la configuración de red del propio navegador
- Redirigimos las peticiones al puerto 8080, que es donde está escuchando Burp
- Capturamos la petición de autenticación y la enviamos a la pestaña *Intruder*
- Desde *Intruder*, parametrizamos el usuario y/o la contraseña usando un diccionario a nuestra elección
- [Lectura recomendable](#)

Ataques fuerza bruta



Attack Data Columns

Results Target Actions Payloads Options

Filter: Showing all items

Request	Payload	Response	Status	Error	Timeout	Length	Charset	Comment
180	admin	HTTP/1.1 200 OK	200		215	215		
197	pharmacyadmin	HTTP/1.1 200 OK	200		215	215		
2	admin	HTTP/1.1 200 OK	200		215	215		
3	administrator	HTTP/1.1 200 OK	200		215	215		
4	admin1	HTTP/1.1 200 OK	200		215	215		
4	admin2	HTTP/1.1 200 OK	200		215	215		
5	admin3	HTTP/1.1 200 OK	200		215	215		
6	admin4	HTTP/1.1 200 OK	200		215	215		
7	pharmacyadmin	HTTP/1.1 200 OK	200		215	215		
8	pharmacyadmin	HTTP/1.1 200 OK	200		215	215		
9	admin	HTTP/1.1 200 OK	200		215	215		
10	admin	HTTP/1.1 200 OK	200		215	215		
11	administrator	HTTP/1.1 200 OK	200		215	215		
12	admin1	HTTP/1.1 200 OK	200		215	215		
13	admin2	HTTP/1.1 200 OK	200		215	215		
14	admin3	HTTP/1.1 200 OK	200		215	215		
15	admin4	HTTP/1.1 200 OK	200		215	215		

Response Response

Raw Headers Info

HTTP/1.1 200 OK text/html
Date: Tue, 22 May 2017 13:11:22 GMT
Server: Apache/2.4.18
Location: http://192.168.1.100/administrator/index.php
Content-Length: 215
Connection: close
Content-Type: text/html; charset=UTF-8

Ejercicio

- Realiza un ataque de diccionario a la aplicación web DV-WA que viene alojada en la distribución Metasploitable2, frente al login web
 - Las credenciales son admin/password



Ejercicio



- Realiza el mismo ejercicio anterior, pero con la herramienta hydra

Ejercicio



- Realiza un ataque de diccionario a la aplicación web DVWA que viene alojada en la distribución Metasploitable2, en concreto a la pestaña “Brute Force” que hay en el índice

- Resuelve la máquina [StrongJenkins](#) de DockerLabs
 - Fuerza bruta con RockYou en Jenkins (usuario admin; la contraseña hay que obtenerla por fuerza bruta)
 - Divide el RockYou en trozos para que lo digiera mejor:
 - `split -n 1/20 rockyou.txt diccionario_`



Ejercicio



- Resuelve la room de TryHackMe sobre [hydra](#)

Ejercicio



- Prueba la herramienta hydra en otras situaciones o contextos, como algunos de los que aparecen [en este documento](#)

Ataque por diccionario al login de WordPress

- El panel de acceso suele estar en `/wp-admin/` o `/wp-login.php`
- Herramientas específicas:
 - **WPScan**: enumera usuarios, plugins y temas, y hace fuerza bruta contra el login
 - `wpscan --url http://<IP>/ --enumerate u`
 - `wpscan --url http://<IP>/ -U admin -P rockyou.txt`
 - **WPSeku**: escáner de vulnerabilidades para WordPress

- Puedes probar a hacer fuerza bruta frente a un WordPress en las máquinas
 - Máquina leemonsqueezy (ya la vimos en enumeración y la veremos en postexplotación)
 - Máquina Loly (la veremos también en postexplotación)

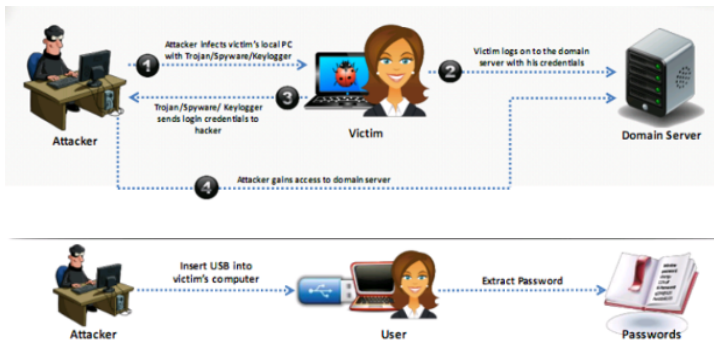


- 1 Introducción
- 2 Ataques online activos
- 3 Ataques de fuerza bruta
- 4 Malware**
- 5 Ataques offline
- 6 Captura de credenciales en red: LLMNR/NBT-NS
- 7 Ataques a tokens en la nube
- 8 Ejercicios
- 9 Referencias

Keylogger

- Es un tipo de malware (software malicioso), o un dispositivo hardware específico, que se encarga de registrar las pulsaciones que se realizan en el teclado
- Se usa para robar credenciales válidas, tarjetas de crédito, PIN, etc.
- Los de tipo software se instalan vía troyano, phishing, etc., y los de tipo hardware requieren una instalación manual
- Este tipo de ataques se suele usar en combinación con técnicas de ingeniería social para potenciar el alcance y la efectividad del ataque (se verá en el tema 3.2)
- En MITRE ATT&CK se corresponde con la técnica [T1056.001 — Keylogging](#)

Keylogger software vs. keylogger hardware



- 1 Introducción
- 2 Ataques online activos
- 3 Ataques de fuerza bruta
- 4 Malware
- 5 Ataques offline**
- 6 Captura de credenciales en red: LLMNR/NBT-NS
- 7 Ataques a tokens en la nube
- 8 Ejercicios
- 9 Referencias

Ataques offline

- Los ataques offline se refieren a las técnicas y herramientas que intentan “romper” una clave cifrada o hasheada.
- Un algoritmo hash no tiene inversa: el proceso de generar el resumen es unidireccional y, dado un resumen, es computacionalmente imposible determinar la entrada que lo generó.
- El atacante hace el proceso inverso por prueba y comparación: cuando encuentra una coincidencia, ha encontrado una contraseña candidata que produce ese hash.
- Estas herramientas se apoyan en *tablas rainbow*, que no son más que tablas precomputadas que sirven a modo de diccionario. Es decir, son diccionarios previamente hasheados o cifrados con diferentes algoritmos; basta con comparar el hash objetivo con la tabla y, si coincide, ya se tiene la contraseña.
- En Windows, el concepto aparece asociado a las credenciales almacenadas en la SAM o en NTDS.dit (MITRE ATT&CK [T1003 — OS Credential Dumping](#)).

¿Qué es el salt?

- Es un valor aleatorio que se añade a una contraseña antes de calcular su hash.
- Sirve para evitar que dos usuarios con la misma contraseña tengan el mismo hash y dificulta enormemente el uso de tablas precalculadas (rainbow tables).
- El salt **no** tiene que mantenerse secreto: normalmente se almacena junto al hash. La seguridad viene de que sea aleatorio y diferente para cada contraseña, no de ocultarlo.
- Referencia: [OWASP Password Storage Cheat Sheet](#).

Ataques offline

Algoritmos de hash y almacenamiento de contraseñas

Aparecieron vulnerabilidades en MD5 (los llamados ataques de colisión), que en ciertas circunstancias permiten obtener una entrada cualquiera dado un resumen. Algoritmos recomendados:

Algoritmo	Uso para contraseñas
MD5	Obsoleto
SHA-1	Obsoleto
SHA-256 directo	No recomendado para almacenar contraseñas
PBKDF2	Adecuado con parámetros apropiados
bcrypt	Adecuado
scrypt	Adecuado
Argon2id	Muy recomendado (RFC 9106)

Véase también [NIST SP 800-63B — Digital Identity Guidelines](#).

Criptografía simétrica: ¿cómo se ataca?

- Normalmente no se “rompe” el algoritmo (AES, ChaCha20, etc.). En la práctica, los ataques intentan obtener la clave o aprovechar una mala implementación:
 - **Fuerza bruta de la clave:** probar sistemáticamente posibles claves hasta encontrar la correcta. Solo es viable cuando la clave es suficientemente pequeña o débil.
 - **Claves débiles o derivadas de contraseñas:** atacar la contraseña de la que se obtiene la clave mediante diccionarios, reglas o fuerza bruta.
 - **Fugas de claves:** localizar las claves en código fuente, ficheros de configuración, variables de entorno, logs, copias de seguridad, repositorios o memoria.
 - **Errores en la implementación:** explotar una utilización incorrecta del algoritmo, por ejemplo, reutilización de IV/nonce, generación de números aleatorios predecibles o una gestión deficiente de claves.
 - **Debilidades del modo de operación:** determinadas configuraciones pueden permitir ataques que revelen o permitan modificar información sin necesidad de romper directamente el algoritmo criptográfico.

- **Ataques criptanalíticos:** aprovechar vulnerabilidades matemáticas conocidas en algoritmos concretos o en determinadas configuraciones.
- **Side-channel attacks:** obtener información sobre la clave analizando características físicas de la ejecución, como tiempos de ejecución, consumo de energía o emisiones electromagnéticas.
- **Compromiso del sistema:** obtener la clave desde un sistema que ya ha sido comprometido, evitando tener que atacar el algoritmo criptográfico.

Criptografía simétrica: opciones más seguras

- **AES-256:** opción estándar, ampliamente analizada y recomendada para cifrado simétrico.
- **AES-GCM:** modo AEAD que proporciona simultáneamente confidencialidad e integridad (autenticación del mensaje).
- **ChaCha20-Poly1305:** alternativa moderna a AES-GCM, especialmente interesante en dispositivos sin aceleración AES por hardware.
- **XChaCha20-Poly1305:** variante de ChaCha20-Poly1305 con un nonce más largo, útil para reducir el riesgo de colisiones de nonce.

Criptografía asimétrica: ¿cómo se ataca?

- **Fuerza bruta:** búsqueda exhaustiva de la clave privada; impracticable con tamaños de clave adecuados.
- **Claves débiles o pequeñas:** tamaños insuficientes pueden permitir ataques criptográficos.
- **Algoritmos obsoletos:** algoritmos que ya no proporcionan un nivel de seguridad adecuado.
- **Exposición de la clave privada:** robo desde ficheros, backups, repositorios, memoria o dispositivos.
- **Contraseñas débiles:** ataque offline contra la contraseña que protege una clave privada.
- **Generación deficiente de claves:** números aleatorios predecibles o parámetros incorrectamente generados.
- **Errores de implementación:** fallos en la implementación del algoritmo o de los protocolos criptográficos.

- **Ataques de canal lateral:** extracción indirecta de información sobre la clave mediante tiempos, consumo, cachés u otras señales.
- **Ataques al protocolo:** explotación de una utilización incorrecta de la criptografía dentro de protocolos como TLS o SSH.
- **Criptoanálisis:** explotación de debilidades matemáticas del algoritmo o de su configuración.
- **Ataques cuánticos:** algoritmos como Shor podrían comprometer RSA y ECC cuando existan ordenadores cuánticos suficientemente potentes.

Criptografía asimétrica: alternativas más seguras

- **X25519**: recomendado para intercambio de claves basado en curvas elípticas.
- **Ed25519**: recomendado para firmas digitales, con buen rendimiento y claves compactas.
- **ECDH/ECDSA**: alternativas ampliamente utilizadas para intercambio de claves y firmas digitales, respectivamente.
- **RSA-2048 o superior**: todavía válido cuando se requiere compatibilidad con sistemas existentes, aunque ECC suele ser preferible en nuevos diseños.
- **ML-KEM (Kyber)**: mecanismo de encapsulación de claves estandarizado para criptografía poscuántica.
- **ML-DSA (Dilithium)**: algoritmo de firma digital poscuántica estandarizado.

Ataques offline

- En este tema nos vamos a centrar en cómo romper claves hasheadas.
- Para ello, disponemos de las siguientes herramientas:
 - **John the Ripper** ([tutorial en castellano](#))
 - `john --wordlist=rockyou.txt hashes.txt`
 - `john --show hashes.txt`
 - **Hashcat**, que aprovecha la GPU ([ejemplo con NTLM](#))
 - `hashcat -m 0 -a 0 hashes.txt rockyou.txt`
 - Identificar el algoritmo del hash:
 - `hashid` y `hash-identifier`
 - Calcular hashes o cifrar con diferentes algoritmos:
 - `openssl`, por ejemplo `echo -n password | openssl dgst -sha256`
- Técnica MITRE ATT&CK asociada: [T1110.002 — Password Cracking](#)

Ataques offline

lqazwed	4259cc34599c530b28a6a8f225d668590
hh021da	c744b1716cbf8d4dd0ff4ce31a177151
9da8dasf	3cd696a8571a843cda453a229d741843
sodifo8sf	c744b1716cbf8d4dd0ff4ce31a177151

Ataques offline

```
msfadmin@metasploitable:~$ sudo mysql
[sudo] password for msfadmin:
Welcome to the MySQL monitor.  Commands end with ; or \g.
Your MySQL connection id is 7
Server version: 5.0.51a-3ubuntu5 (Ubuntu)

Type 'help;' or '\h' for help. Type '\c' to clear the buffer.

mysql> show databases;
+-----+
| Database |
+-----+
| information_schema |
| dvwa      |
| metasploit |
| mysql     |
| owasp10   |
| tikiwiki  |
| tikiwiki195 |
+-----+
7 rows in set (0.00 sec)
```

```
mysql> use dvwa;
Database changed
mysql> show tables;
+-----+
| Tables_in_dvwa |
+-----+
| guestbook      |
| users          |
+-----+
2 rows in set (0.00 sec)
```

Ataques offline

Se identifica que los passwords están en un formato hash MD5

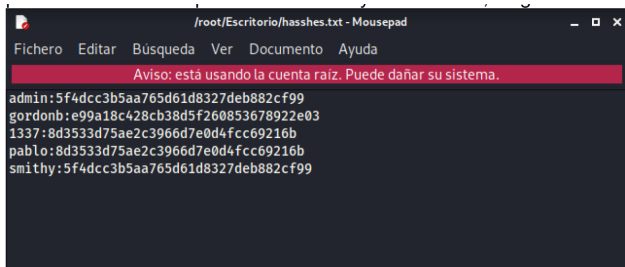
```
mysql> select * from users;
```

user_id	first_name	last_name	user	password	avatar
1	admin	admin	admin	5f4dcc3b5aa765d61d8327deb882cf99	http://172.16.123.129/dvwa/hackable/users/admin.jpg
2	Gordon	Brown	gordonb	e99a18c428cb38d5f260853678922e03	http://172.16.123.129/dvwa/hackable/users/gordonb.jpg
3	Hack	Me	1337	8d3533d75ae2c3966d7e0d4fcc69216b	http://172.16.123.129/dvwa/hackable/users/1337.jpg
4	Pablo	Picasso	pablo	0d107d09f5bbe40cade3de5c71e9e9b7	http://172.16.123.129/dvwa/hackable/users/pablo.jpg
5	Bob	Smith	smithy	5f4dcc3b5aa765d61d8327deb882cf99	http://172.16.123.129/dvwa/hackable/users/smithy.jpg

```
5 rows in set (0.00 sec)
```

```
mysql>
```

Se descargan los hashes de los usuarios de la base de datos y se descargan los hashes



The screenshot shows a text editor window titled "/root/Escritorio/hasshes.txt - Mousepad". The window contains a list of usernames and their corresponding MD5 hashes, separated by a colon. The text is as follows:

```
Fichero  Editar  Búsqueda  Ver  Documento  Ayuda
```

Aviso: está usando la cuenta raíz. Puede dañar su sistema.

```
admin:5f4dcc3b5aa765d61d8327deb882cf99
gordonb:e99a18c428cb38d5f260853678922e03
1337:8d3533d75ae2c3966d7e0d4fcc69216b
pablo:8d3533d75ae2c3966d7e0d4fcc69216b
smithy:5f4dcc3b5aa765d61d8327deb882cf99
```

Ataques offline

que descubre los MD5.

```
root@kali: ~  
Archivo Acciones Editar Vista Ayuda  
(root@kali)-[~]  
# john --format=raw-MD5 /root/Escritorio/hashes.txt 1 x  
Using default input encoding: UTF-8  
Loaded 5 password hashes with no different salts (Raw-MD5 [MD5 128/128 AVX 4x3])  
Warning: no OpenMP support for this hash type, consider --fork=4  
Proceeding with single, rules:Single  
Press 'q' or Ctrl-C to abort, almost any other key for status  
Warning: Only 5 candidates buffered for the current salt, minimum 12 needed for performance.  
Warning: Only 8 candidates buffered for the current salt, minimum 12 needed for performance.  
Almost done: Processing the remaining buffered candidate passwords, if any.  
Warning: Only 6 candidates buffered for the current salt, minimum 12 needed for performance.  
Proceeding with wordlist:/usr/share/john/password.lst, rules:Wordlist  
password (admin)  
password (smithy)  
abc123 (gordonb)  
Proceeding with incremental:ASCII  
charley (1337)  
charley (pablo)  
5g 0:00:00:00 DONE 3/3 (2021-05-09 20:41) 6.250g/s 227513p/s 227513c/s 470196C/s stevy13..chert  
su  
Use the "--show --format=Raw-MD5" options to display all of the cracked passwords reliably  
Session completed  
(root@kali)-[~]  
#
```


Ejercicio



Conéctate de manera remota a la BBDD MySQL de Metasploitable2, accede a las contraseñas almacenadas y recupera las claves en claro.

El mismo ejercicio con Metasploit

- Módulos auxiliares para MySQL:
 - `auxiliary/admin/mysql/mysql_sql` # ejecutar SQL (`show databases;`)
 - `auxiliary/scanner/mysql/mysql_schemadump` # volcar el esquema completo
 - `auxiliary/scanner/mysql/mysql_hashdump` # usuarios + hashes
- Con `root/123` se enumeran las bases de datos, se vuelca todo el esquema y se extraen los hashes de los usuarios MySQL (crackeables después con John o Hashcat)
- Hacia RCE:
 - `auxiliary/scanner/mysql/mysql_writable_dirs` # directorios escribibles
 - Con `secure_file_priv` vacío y privilegio `FILE` → escribir ficheros (webshell o UDF)

Ataques offline

```
msf5 auxiliary(admin/mysql/mysql_sql) > show options
```

```
Module options (auxiliary/admin/mysql/mysql_sql):
```

Name	Current Setting	Required	Description
PASSWORD	root	no	The password for the specified username
RHOSTS	192.168.56.102	yes	The target address range or CIDR identifier
RPORT	3306	yes	The target port (TCP)
SQL	show databases;	yes	The SQL to execute.
USERNAME	root	no	The username to authenticate as

```
msf5 auxiliary(admin/mysql/mysql_sql) > run
```

```
*] 192.168.56.102:3306 - Sending statement: 'show databases;...'
*] 192.168.56.102:3306 - | information_schema |
*] 192.168.56.102:3306 - | dvwa |
*] 192.168.56.102:3306 - | metasploit |
*] 192.168.56.102:3306 - | mysql |
*] 192.168.56.102:3306 - | owasp10 |
*] 192.168.56.102:3306 - | tikiwiki |
*] 192.168.56.102:3306 - | tikiwiki195 |
*] Auxiliary module execution completed
msf5 auxiliary(admin/mysql/mysql_sql) >
```

Realiza un ataque offline al fichero shadow de Metasploitable2

- Para ello, deberás juntar el fichero `passwd` (usuarios) y el fichero `shadow` (contraseñas) mediante:
 - `unshadow passwd.txt shadow.txt > passwords`
- A partir de ese fichero, ya puedes lanzar John the Ripper



Ejercicio

- John the Ripper se puede usar también para romper el cifrado de múltiples formatos, por ejemplo de un fichero ZIP
- ¿Serías capaz de romper el cifrado del fichero `reto1`?
 - Pista: usa `zip2john` para extraer la clave cifrada del fichero y, sobre esa salida, ya puedes lanzar John
 - `zip2john reto1.zip > reto1.hash`
 - `john --wordlist=rockyou.txt reto1.hash`



Ejercicio



- Resuelve la máquina [Crocodile](#) de HackTheBox (Starting Point)

- 1 Introducción
- 2 Ataques online activos
- 3 Ataques de fuerza bruta
- 4 Malware
- 5 Ataques offline
- 6 Captura de credenciales en red: LLMNR/NBT-NS**
- 7 Ataques a tokens en la nube
- 8 Ejercicios
- 9 Referencias

LLMNR/NBT-NS poisoning attack

- LLMNR (Link-Local Multicast Name Resolution) y NBT-NS (NetBIOS Name Service) son protocolos usados en redes Windows para resolver nombres de host cuando el DNS falla.
- Permiten que los equipos descubran otros dispositivos localmente sin necesidad de un servidor DNS.
- ¿En qué consiste el ataque?
 - Un atacante se coloca en la red local y escucha las peticiones LLMNR/NBT-NS de los equipos.
 - Cuando una máquina intenta resolver un nombre no existente (por ejemplo, \\servidor), el atacante responde falsamente haciéndose pasar por ese servidor.
 - El equipo víctima envía sus credenciales (hashes NTLMv2) al atacante.
- Técnica MITRE ATT&CK: [T1557.001 — LLMNR/NBT-NS Poisoning and SMB Relay](#)

Herramienta: Responder

- La herramienta **Responder** suplanta servicios de red comunes (SMB, HTTP, LDAP, etc.) para capturar los hashes NTLMv2:
 - `responder -I eth0 -wv`
 - Permite después realizar ataques offline (cracking de los hashes capturados)
 - Y ataques de *relay*, si se combina con herramientas como **ntlmrelayx** (Impacket)
- Mitigaciones
 - Deshabilitar LLMNR y NBT-NS en entornos corporativos.
 - Implementar DNS fiable y autenticación basada en Kerberos.
 - Usar SMB signing y seguridad de red avanzada (LAPS, EDR, etc.).

Ejercicio



- Realiza un ataque usando la herramienta [Responder](#). A partir de los hashes capturados, se pueden aplicar ataques offline (John the Ripper) para obtener las credenciales. [Ejemplo](#)

- 1 Introducción
- 2 Ataques online activos
- 3 Ataques de fuerza bruta
- 4 Malware
- 5 Ataques offline
- 6 Captura de credenciales en red: LLMNR/NBT-NS
- 7 Ataques a tokens en la nube**
- 8 Ejercicios
- 9 Referencias

Token Abuse en Azure / Entra ID: tipos de token

- Las organizaciones modernas autentican en la nube mediante tokens JWT: robar un token equivale a robar las credenciales sin conocer la contraseña.
- Tipos de token en Azure / Entra ID:
 - **Access Token:** JWT de corta vida (~1 h). Autoriza el acceso a un recurso concreto (API, Graph...)
 - **Refresh Token:** mayor duración. Permite obtener nuevos access tokens sin reautenticación
 - **PRT (Primary Refresh Token):** vida larga (~90 días), almacenado en el dispositivo unido a Entra ID. Comprometer un PRT equivale a un Golden Ticket en el Active Directory clásico
 - **ID Token:** contiene los claims de identidad del usuario (no autoriza, identifica)
- Documentación: [Microsoft Entra — Access tokens](#)

Token Abuse

Vectores de ataque y técnicas

- Vectores de ataque:
 - Malware en el endpoint que lee tokens del navegador o del proceso LSASS
 - Phishing de código de dispositivo (Device Code Phishing)
 - Acceso físico al equipo unido a Entra ID (extracción del PRT vía DPAPI)
 - Sesiones de navegador no cerradas, o tokens almacenados en disco o en sincronización cloud
- Técnicas de abuso de tokens:
 - **Pass-the-Token:** usar un token robado para autenticarse (análogo a Pass-the-Hash)
 - **PRT Hijacking:** extraer el PRT para generar nuevos tokens sin MFA
 - **Device Code Phishing:** engañar al usuario para que autorice un token vía un código de 8 dígitos
 - **Refresh Token Theft:** un refresh token robado genera access tokens indefinidamente
 - **Golden SAML:** forjar aserciones SAML con la clave privada robada del IdP
- Técnica MITRE ATT&CK: [T1528 — Steal Application Access Token](#)

Herramientas y mitigaciones

■ Herramientas:

- **AADInternals** (PowerShell): extraer el PRT, crear tokens y administrar Entra ID
- **roadrecon** (Python): enumerar Azure AD / Graph API
- **mimikatz**: módulo DPAPI, para extraer el PRT de LSASS en un Windows unido a Entra ID
- **TokenTactics**: manipulación avanzada de tokens de Entra ID

■ Mitigaciones clave:

- **CAE** (Continuous Access Evaluation): revocación de tokens en tiempo real
- Conditional Access, con restricciones de ubicación y de dispositivo
- FIDO2 / Passkeys: autenticación sin contraseña ni token robable
- Token binding y reducción de la vida útil del refresh token

Top 5 Password Attack Types

Cyber Writes



Brute Force Attack

A brute force attack is a type of password crack that uses a computer program to generate and try every possible combination of characters until it finds the correct password. This attack is very time-consuming and often requires large amounts of computing power, but it can be successful if the attacker has enough time and resources.



Dictionary Attack

A dictionary attack is a type of password crack that uses a list of words (usually taken from a dictionary) to generate and try possible password combinations. This attack can be very effective if the password is a common word or phrase, but it is much less likely to succeed if the password is a random string of characters.



Rainbow Table Attack

A rainbow table attack is a type of password crack that uses a pre-computed table of all possible hashes of all possible passwords (or a subset thereof). This attack can be very effective if the attacker has a copy of the rainbow table, but it is much less likely to succeed if the password is a random string of characters.



Social Engineering Attack

A social engineering attack is a type of password crack that relies on tricking the user into revealing their password. This attack can be successful if the attacker is skilled at deception, but it is much less likely to succeed if the user is aware of the risks.



credential stuffing Attack

A credential stuffing attack is a type of password crack that uses a list of stolen usernames and passwords (usually obtained from an external data breach) to try and gain access to other accounts. This attack can be successful if the user re-uses passwords across multiple accounts, but it is much less likely to succeed if the user has a unique password for each account.

- 1 Introducción
- 2 Ataques online activos
- 3 Ataques de fuerza bruta
- 4 Malware
- 5 Ataques offline
- 6 Captura de credenciales en red: LLMNR/NBT-NS
- 7 Ataques a tokens en la nube
- 8 Ejercicios**
- 9 Referencias

Ejercicio

- Resuelve el siguiente reto de TryHackMe: [Crack The Hash](#)
- Útil para identificar de qué hash se trata:
 - La herramienta `hash-identifier`
 - Un cracker online: [CrackStation](#)



- Resuelve la máquina **Brute-It** de TryHackMe, para ello necesitas:
 - Enumeration
 - Content Discovery
 - Exploitation
 - Login Brute Forcing
 - John the Ripper sobre un id_rsa (Hash cracking)



Ejercicio

- Resuelve la máquina [Brooklyn-nine-nine](#) de TryHackMe, para ello:
 - Enumeration
 - Leak información vía ftp
 - Exploitation
 - Login Brute Forcing



- Resuelve la máquina [Hackernote](#) de TryHackMe, para ello necesitas:
 - Escaneo + Enumeración
 - ... y aplicar fuerza bruta explotando una debilidad de timing para obtener el usuario
 - Hydra para sacar la password



Ejercicio

- Resuelve la máquina [Bounty Hacker](#) de TryHackMe, para ello necesitas:
 - Escaneo + Enumeración
 - Encontrar un fichero con credenciales en ftp
 - ... y aplicar fuerza bruta basada en diccionario al servicio ssh



Ejercicio

- Resuelve la máquina [Easy Peasy](#) de TryHackMe, para ello necesitas:
 - Escaneo + Enumeración en el puerto 80
 - Inspeccionar robots.txt y código fuente web
 - Decodificar hashes con dcode.fr/base62-encoding
 - Enumerar en el puerto 65524
 - Decodificar md5 en md5hashing.net/hash
 - Esteganografía con diccionario
 - Decodificar binario con [CyberChef](#)



Ejercicio

- Realiza un ejercicio de fuerza bruta basado en diccionario usando herramientas de enumeración como `wfuzz` o `ffuf`
- Para ello, puedes construir una petición POST (por ejemplo, con la opción `--request`) frente a la autenticación de DVWA y usar `FUZZ` y `FUZZ2Z` para fuzzear usuarios y contraseñas



- 1 Introducción
- 2 Ataques online activos
- 3 Ataques de fuerza bruta
- 4 Malware
- 5 Ataques offline
- 6 Captura de credenciales en red: LLMNR/NBT-NS
- 7 Ataques a tokens en la nube
- 8 Ejercicios
- 9 Referencias**

Estándares y guías de referencia

- NIST SP 800-63B, *Digital Identity Guidelines: Authentication and Lifecycle Management*. pages.nist.gov
- OWASP, *Authentication Cheat Sheet*. cheatsheetseries.owasp.org
- OWASP, *Password Storage Cheat Sheet*. cheatsheetseries.owasp.org
- OWASP, *Credential Stuffing Prevention Cheat Sheet*. cheatsheetseries.owasp.org
- OWASP, *Web Security Testing Guide* — sección de autenticación. owasp.org/www-project-web-security-testing-guide
- Biryukov, Dinu, Khovratovich y Josefsson, *Argon2 Memory-Hard Function for Password Hashing*, RFC 9106, 2021

Técnicas MITRE ATT&CK tratadas en el tema

- T1110 — Brute Force (Password Guessing, Password Cracking, Password Spraying, Credential Stuffing)
- T1003 — OS Credential Dumping
- T1056.001 — Input Capture: Keylogging
- T1557.001 — LLMNR/NBT-NS Poisoning and SMB Relay
- T1528 — Steal Application Access Token

Documentación de herramientas

- John the Ripper — documentación oficial (Openwall)
- Hashcat — wiki oficial
- Nmap Scripting Engine — capítulo del libro de Nmap
- HackTricks — Brute Force
- Hitaj, Gasti, Ateniese y Pérez-Cruz, *PassGAN: A Deep Learning Approach for Password Guessing*, ACNS 2019. [arXiv:1709.00440](https://arxiv.org/abs/1709.00440)

¡Gracias!

Seguridad en Sistemas Informáticos — Tema 3.1